

Пентест-лаборатория Active Directory на одном компьютере: Профессиональный подход к экономии ресурсов

 redsec.by/article/pentest-laboratoriya-active-directory-na-odnom-kompyutere-professionalnyj-podhod-k-ekonomii-resursov

Red Teams | 23 октября 2025



Мечта любого специалиста по кибербезопасности — иметь под рукой разветвленный киберполигон: несколько доменов, десятки серверов и рабочих станций, сложная сетевая топология. Но реальность часто упирается в ресурсы одного-единственного рабочего компьютера. Пытаться запустить 4-5 полноценных виртуальных машин с

графическим интерфейсом на ноутбуке с 16 ГБ оперативной памяти — это гарантированный путь к разочарованию и перегреву процессора.

Означает ли это, что без мощной рабочей станции путь к практике пентеста AD закрыт? Абсолютно нет.

Как опытный специалист, я могу заверить: дело не в количестве запущенных виртуальных машин, а в умном и экономном подходе к их созданию. Нам не нужно имитировать *офисную работу* на пяти компьютерах одновременно. Нам нужно создать **атакуемую сетевую сущность Active Directory**, которая будет вести себя как большая сеть, но потреблять ресурсы как небольшое приложение.

Это руководство — концентрированный опыт по созданию полнофункциональной, но легковесной лаборатории Active Directory на одной машине.

Шаг 1: Фундамент — Оценка ресурсов и выбор правильных инструментов

Прежде чем строить дом, нужно оценить участок.

- **Оперативная память (ОЗУ/RAM):** Это ваш главный и самый ценный ресурс.
 - **16 ГБ:** Абсолютный минимум. Будет тесно, но при правильном подходе все заработает. Вам придется внимательно следить за потреблением и, возможно, отключать неиспользуемые ВМ.
 - **32 ГБ:** Комфортный и рекомендуемый объем. Позволит вам не думать о каждом мегабайте и даже запустить дополнительные сервисы, вроде SIEM-системы.
- **Дисковое пространство:** Только **SSD**. Запуск нескольких операционных систем одновременно создает колоссальную нагрузку на подсистему ввода-вывода (I/O). Использование традиционного HDD превратит вашу работу в пытку из-за постоянных "фризов". 150-200 ГБ свободного места будет достаточно.
- **Процессор:** Подойдет любой современный процессор с 4+ ядрами и поддержкой виртуализации (Intel VT-x или AMD-V), которая включена в BIOS/UEFI.
- **Гипервизор:**
 - **Oracle VM VirtualBox (бесплатно):** Отличный выбор для начала. Он прост, кроссплатформенен и обладает всем необходимым функционалом, включая управление сетями и снапшотами.
 - **VMware Workstation Player (бесплатно для некоммерческого использования):** Альтернатива от VMware.
 - **VMware Workstation Pro (платно):** Считается золотым стандартом за продвинутые сетевые настройки, клонирование и работу со снапшотами. Если есть возможность, это лучший выбор.

Шаг 2: "Золотое правило" — Минимализм и легковесность

Ключ к успеху — отказаться от всего лишнего. Каждая виртуальная машина должна быть сконфигурирована на минимально возможное потребление ресурсов.

1. Контроллер домена (DC): Только Server Core!

Это самый важный трюк, экономящий гигабайты ОЗУ. Вместо установки Windows Server с полноценным рабочим столом (Desktop Experience), разворачивайте контроллер домена на **Windows Server Core**.

- **Что это?** Это официальный вариант установки Windows Server, в котором полностью отсутствует графический интерфейс — нет меню "Пуск", нет иконок, нет Проводника. Только командная строка (CMD) и PowerShell.
- **Почему это меняет все?**
 - **Потребление ОЗУ:** Server Core в состоянии покоя потребляет **~500-700 МБ** ОЗУ. Версия с GUI легко отъедает **2-4 ГБ**. Вы только что сэкономили 2-3 ГБ на одной только ВМ!
 - **Производительность:** Меньше фоновых процессов — выше производительность и меньше нагрузка на процессор.
- **Как управлять?** Управлять таким сервером можно либо напрямую через PowerShell, либо удаленно с помощью RSAT (Remote Server Administration Tools), установленных на вашу клиентскую ВМ с Windows 10/11.
- **Рекомендуемые ресурсы для ВМ:** 1-2 vCPU, **2 ГБ ОЗУ**.

2. Рабочие станции: Одна настоящая, остальные — "фантомы"

Здесь кроется второй профессиональный трюк. Вам не нужно запускать 3-4 ВМ с Windows 10.

- **Одна полноценная станция (1 ВМ):** Вам нужна ровно одна клиентская ВМ с **Windows 10 или 11**. Это будет ваш плацдарм для атаки: точка входа в сеть, место для запуска инструментов разведки (SharpHound, PowerView), машина, на которой вы будете пытаться повысить привилегии. Сделайте ее максимально легкой: отключите визуальные эффекты, ненужные службы.

Рекомендуемые ресурсы для ВМ: 1-2 vCPU, **2-4 ГБ ОЗУ**.

- **"Фантомные" рабочие станции и серверы (0 ВМ):** Для большинства атак (Kerberoasting, поиск неправильных ACL, атаки на делегирование) не нужен работающий компьютер. Нужен **объект "Компьютер" в Active Directory**, у которого есть свойства.
 - **Реализация:** Просто откройте оснастку "Active Directory Users and Computers" (можно с вашей ВМ на Windows 10) и создайте в каталоге несколько компьютерных аккаунтов: WEB-SRV01, SQL-SRV01, FINANCE-WKSTN и так далее.
 - **Результат:** Теперь вы можете назначать этим *объектам* уязвимые параметры (например, неограниченное делегирование для WEB-SRV01), создавать для них SPN-записи для атаки Kerberoasting. Они существуют в AD, их можно "видеть" и атаковать на уровне протоколов, но они **не потребляют ни одного мегабайта ОЗУ или такта CPU**.

3. Атакующая машина (1 ВМ):

Используйте стандартный **Kali Linux** или **Parrot OS**. Они достаточно оптимизированы.

Рекомендуемые ресурсы для ВМ: 1-2 vCPU, 2-4 ГБ ОЗУ.

Итог по ресурсам:

Виртуальная машина	Рекомендуемая ОЗУ	Примечание
Контроллер домена (Server Core)	2 ГБ	Максимальная экономия ресурсов
Рабочая станция (Windows 10)	3 ГБ (в среднем)	Единственная клиентская ВМ с GUI
Атакующая машина (Kali Linux)	3 ГБ (в среднем)	Стандартный инструмент пентестера
Общее потребление	~8 ГБ	Комфортно помещается в 16 ГБ ОЗУ хоста!

Шаг 3: Автоматизация для экономных — Выбор правильного сценария

Даже с учетом экономии, ручная настройка всего этого — долгий процесс. Готовые решения, такие как **GOAD (Game of Active Directory)**, уже учитывают потребность в экономии.

Вместо развертывания полной версии, используйте легковесные конфигурации:

- **GOAD-Light:** Сокращенная версия, которая разворачивает 3 ВМ (DC, сервер, Windows 10) и один домен. Идеальный баланс между сложностью и потреблением ресурсов.
- **MINILAB:** Минималистичная версия, состоящая всего из 2 ВМ (DC и Windows 10). Прекрасно подходит для отработки 90% всех базовых и средних атак на AD.

Развертывание запускается одной командой, например:

```
# Клонировем репозиторий
git clone https://github.com/Orange-Cyberdefense/GOAD.git
cd GOAD

# Запускаем установку легковесной лаборатории для VirtualBox
./goad.sh -t install -l GOAD-Light -p virtualbox
```

Шаг 4: Секретное оружие профессионала — Снапшоты

Работа без снапшотов (snapshots) — это как работа сапера без защитного костюма. Это самая важная часть рабочего процесса.

- **Создайте "чистый" снапшот:** Сразу после того, как лаборатория развернута и вы убедились, что все ВМ запущены и видят друг друга, **немедленно сделайте снапшот каждой виртуальной машины**. Назовите его "Baseline" или "Clean Install".
- **Атакуйте без страха:** Теперь вы можете делать что угодно. Зашифровать контроллер домена, удалить системные файлы, запустить самые деструктивные эксплойты.
- **Мгновенный откат:** Когда атака завершена или что-то пошло не так, не нужно ничего переустанавливать или чистить. Просто **верните все ВМ к состоянию "Baseline"**. Этот процесс занимает меньше минуты.

Этот цикл "**Снапшот -> Атака -> Откат**" экономит десятки часов и позволяет проводить эксперименты с полной свободой и без последствий.

Профессиональный подход — это не про мощность, а про эффективность

Развертывание пентест-лаборатории на одном компьютере — это не компромисс, а инженерная задача. Применяя описанные методы — использование Windows Server Core, создание "фантомных" объектов вместо реальных ВМ и активное использование снапшотов, — вы можете создать мощный, гибкий и ресурсоэффективный киберполигон даже на среднем ноутбуке.

Этот подход не только экономит ресурсы вашего компьютера, но и учит вас главному принципу в кибербезопасности: глубокое понимание технологий позволяет достигать целей более элегантно и эффективно, чем метод грубой силы.

